

Narrativa explicativa del marco GQM + PRAGMATIC aplicado a INES-ENS

Donde descubrimos que las métricas también tienen biografía, motivaciones y, a veces, complejos de inferioridad.

1. Del ENS y el INES a la necesidad de saber “por qué” medimos

El ENS y el RD 311/2022 obligan a las organizaciones públicas y a sus socios tecnológicos a evaluar periódicamente su estado de seguridad y a demostrar una conformidad razonable con un conjunto no precisamente pequeño de medidas.[web:37][web:40][web:41] INES aparece como el canal oficial donde ese esfuerzo se destila en indicadores nacionales, mientras las guías CCN-STIC 815 y 824 recuerdan que no basta con saber “qué controles hay”, sino “cómo funcionan y qué impacto tienen”. [web:20][web:33][web:38]

En ese contexto, multiplicar las métricas sin una brújula conduce a la parálisis: hojas de cálculo extensas, paneles vistosos y una sensación difusa de que nadie sabe ya qué número importa. El marco GQM + PRAGMATIC entra en escena precisamente para evitar eso: obliga a justificar cada métrica (Goal-Question-Metric) y a interrogar su calidad y utilidad (PRAGMATIC), antes de concederle un hueco en el altar del cuadro de mando.

2. GQM: evitar la “colección de cromos” métricos

La lógica de GQM es casi insultantemente sencilla: ningún número sin pregunta, ninguna pregunta sin objetivo. En el mundo ENS-INES, esto significa que:

- No se mide “por medir”, sino porque hay un objetivo alineado con ENS (por ejemplo, mejorar la madurez en gestión de incidentes) y con el mandato nacional (mejorar la resiliencia del sector público).[web:8][web:37][web:39]
- Cada pregunta se formula con un pie en la norma y otro en la realidad: “¿disminuyen los incidentes graves?” o “¿se cumplen los RTO marcados en los planes de continuidad?”.

Cuando se aplica GQM a los dominios ENS-INES, muchas métricas que llevaban años en plantillas estándar revelan su condición de “relleno”: nadie recuerda para qué se crearon, nadie decide nada en función de ellas y, aun así, alguien sigue alimentándolas. El primer efecto del marco suele ser terapéutico: una reducción saludable del ruido.

3. PRAGMATIC: poner a las métricas ante el espejo

La segunda parte, PRAGMATIC, es menos conocida pero igual de necesaria. Obliga a preguntar, sin piedad pero con cariño, si una métrica es:

- Predictiva o solo retrospectiva.
- Relevante de verdad, o simplemente tradicional.
- Accionable, o solo decorativa.
- Genuina y resistente al maquillaje.
- Significativa para quien debe leerla.
- Precisa en la medida de lo necesario.
- Oportuna (no llega tarde a la fiesta).
- Independiente de los intereses de quien la calcula.
- Rentable, esto es, que no cueste más obtenerla que el valor que aporta.

Aplicar PRAGMATIC a los indicadores ENS–INES produce hallazgos curiosos. Por ejemplo, el porcentaje de medidas implantadas es muy relevante y accionable, pero su genuinidad y precisión dependen enormemente de la cultura de honestidad interna y del rigor de las auditorías. En otras palabras: ese cómodo “90 % implantado” puede vivir una vida ficticia si nadie se toma en serio su verificación.

[web:18][web:38][web:33]

En cambio, métricas como el tiempo medio de detección y respuesta, o el número de interrupciones de servicios críticos, suelen salir bien paradas: son más difíciles de maquillar, están íntimamente ligadas a la experiencia de negocio y generan reacciones inmediatas cuando se degradan.

4. Cómo esto ayuda a ENS–INES a ser algo más que un trámite

El espíritu del ENS, reforzado por el RD 311/2022 y las últimas guías, es el de una gestión de riesgos y madurez que vaya más allá de la conformidad literal.[web:37][web:20][web:33] INES, utilizado como espejo nacional, solo será útil si los números que recoge tienen significado estratégico. El marco GQM + PRAGMATIC propone tres mejoras concretas:

1. Selección consciente: no todas las métricas posibles se reportan, solo las que tengan una buena justificación GQM y un perfil PRAGMATIC razonable.
2. Trazabilidad vertical: una línea clara conecta el objetivo nacional (por ejemplo, reducir incidentes graves en servicios esenciales) con las métricas locales (incidentes por 1.000 activos, cumplimiento de RTO, madurez en gestión de incidentes).
3. Priorización y limpieza anual: si una métrica lleva años con baja relevancia, poca acción asociada y escaso uso real en decisiones, la recomendación es clara: se retira del cuadro de mando o se rediseña.

Este enfoque encaja bien con la propia lógica de las guías CCN-STIC, que insisten en ajustar indicadores al contexto y en no limitarse a reproducir listas de controles.[web:20][web:33]

5. GQM + PRAGMATIC en la práctica: del Excel al informe ejecutivo

En la práctica, el viaje va de lo técnico a lo estratégico en varias estaciones:

4. En la base, equipos técnicos y de seguridad definen y mantienen las métricas inspiradas en las preguntas GQM, nutriéndose de sistemas como LUCÍA, PILAR, herramientas GRC y el propio INES. [web:8][web:30][web:32]
5. En la capa intermedia, la plantilla Excel para IGM y ROI integra esos datos, calcula índices y permite analizar tendencias (por ejemplo, cómo varía el IGM frente al número de incidentes).
6. En la cúspide, la plantilla de reporte ejecutivo convierte esos índices en mensajes comprensibles: la alta dirección no necesita ver todas las métricas, solo aquellas que puntúan alto en relevancia, acción y significado.

La narrativa resultante deja de ser “hemos implantado el 87 % de las medidas ENS” para convertirse en “nuestro índice de madurez ha pasado de 2,6 a 3,2 en dos años; los incidentes graves han caído un 40 % y el tiempo de recuperación medio se ha reducido a la mitad”. Ese cambio de densidad narrativa es precisamente el terreno natural de GQM + PRAGMATIC.

6. Y, por supuesto, qué hacer con las métricas “feas”

Algunos indicadores saldrán mal en su evaluación PRAGMATIC; son las métricas “feas” del cuento. No son malas personas, pero quizá estén en el lugar equivocado:

- Las que son baratas pero poco relevantes pueden conservarse como insumo técnico, sin sobrecargar el informe ejecutivo.
- Las que son relevantes pero muy costosas obligan a pensar en automatización o en simplificación.
- Las que ni son relevantes, ni accionables, ni genuinas deberían tener su ceremonia de jubilación digna.

El mensaje implícito, muy ensiano, es que medir también es gestionar: decidir qué se mide, cómo y para qué, forma parte de la responsabilidad de seguridad tanto como implantar un firewall o redactar una política.

El día que alguien, ante un gráfico de IGM y de incidentes, pregunte “¿qué métrica hemos dejado de medir porque no servía para nada?”, sabremos que PRAGMATIC ha hecho su modesto trabajo.